



SNOWBE ONLINE Policy# VM-1

Vulnerability Management

Your name: Jarred Ward

Vulnerability Management – Version 1.0

DATE: 11/3/2025

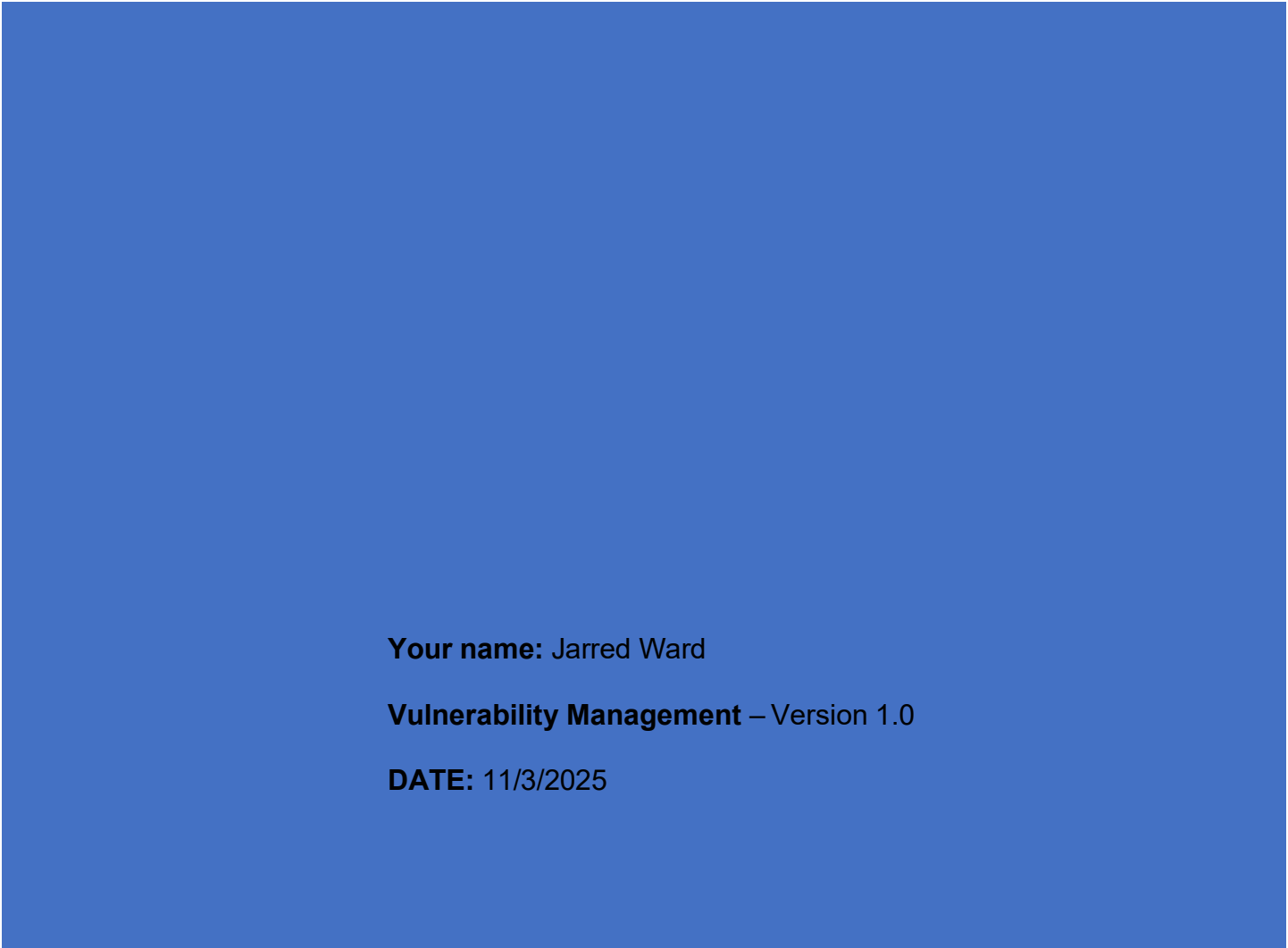


Table of Contents

PURPOSE..... 2

SCOPE..... 2

DEFINITIONS..... 2

ROLES & RESPONSIBILITIES 2

POLICY 3

EXCEPTIONS/EXEMPTIONS 3

ENFORCEMENT 4

VERSION HISTORY TABLE 4

CITATIONS 5

Purpose

The purpose of this policy is to define the procedures SnowBe Online uses to identify, assess, and remediate vulnerabilities across its information systems. Consistent vulnerability management ensures that SnowBe reduces exposure to threats, maintains system integrity, and satisfies compliance obligations under NIST 800-53 and PCI DSS.

Scope

This policy applies to all SnowBe Online employees, contractors, and third-party vendors who manage or support company systems. It includes all AWS-hosted and on-premise infrastructure, endpoints, network devices, and applications used in corporate offices and retail operations.

Definitions

Configuration Baseline

A secure reference standard for system setup that ensures consistency across SnowBe environments.

Patch

A software update intended to fix security flaws and improve performance.

Remediation

The process of resolving identified vulnerabilities through corrective actions or mitigation controls.

Vulnerability

A weakness in hardware, software, or configuration that could be exploited to compromise the confidentiality, integrity, or availability of systems.

Vulnerability Scan

An automated tool-based review that detects misconfigurations or known security weaknesses.

Roles & Responsibilities

Chief Information Security Officer (CISO)

The CISO oversees SnowBe Online's information security strategy, ensuring alignment with business goals, NIST 800-53 controls, and PCI DSS compliance. This role leads risk management, approves major security initiatives, and reports the company's security posture to executive leadership.

Employees and Contractors

Employees and contractors must follow all security procedures, protect company and customer data,

and report suspicious activities immediately. They are responsible for completing mandatory security awareness training and adhering to acceptable use policies.

IT Security Manager

The IT Security Manager implements and enforces security controls across SnowBe's AWS and on-premise systems. This role manages daily operations, coordinates vulnerability management, and ensures policy compliance through training and incident oversight.

Network Administrator

The Network Administrator secures and maintains network infrastructure, including VPNs, firewalls, and routers. This role ensures proper segmentation between corporate systems and the cardholder data environment.

System Administrators

System Administrators maintain secure system configurations, manage user access, and perform regular updates and backups. They support incident response efforts and ensure systems meet SnowBe's security and compliance standards.

Policy

SnowBe Online shall conduct vulnerability scans at least monthly and after any major system change. Vulnerabilities will be classified by severity and remediated within defined timeframes: Critical within fourteen days, High within thirty days, and Medium or Low within sixty days, unless adjusted by documented risk analysis. Patches and configuration updates must be tested before deployment to prevent operational impact. Unsupported or unpatched systems must be isolated or decommissioned, and it is unacceptable to disable or postpone critical security updates without documented approval. All remediation activities and scan reports will be documented and retained for one year. The IT Security Manager will review results quarterly to confirm compliance with PCI DSS and NIST 800-53 requirements.

Exceptions/Exemptions

Requests for exceptions must be submitted in writing to SnowBe Online's IT Security Manager for review and approval. Each request must include the business justification, defined scope, duration, and any compensating controls that will be applied. All approved exceptions will be formally documented, reviewed periodically for continued appropriateness, and remain valid for no longer than one year unless re-evaluated and re-approved.

Enforcement

Failure to follow this policy may result in disciplinary action, beginning with a verbal warning and escalating to written notice, suspension of system access, or termination of employment. Contractors and vendors who violate SnowBe Online’s security or compliance requirements may have their access revoked or contracts terminated. Intentional or severe violations, especially those involving customer data or payment systems, may lead to termination and potential legal or regulatory action under applicable laws.

Version History Table

Version #	Implementation Date	Document Owner	Approved By	Description
1.0	11/3/2025	Jarred Ward	IT Security Manager	Original Draft

Citations

Coastal Carolina University - <https://www.coastal.edu/uploads/policies/pdf/univ-484-february 2023.pdf>
– (Used for Roles & Responsibilities)

Fordham University - <https://www.fordham.edu/information-technology/it-security--assurance/it-policies-procedures-and-guidelines/vulnerability-management-policy/> (Used for Definitions).

Trinity University - https://policies.trinity.edu/14f3ca77-8fc4-4458-9703-987fab5cff78.pdf?v=8FOcCzdz6EWfiwijt_pZQw2 (Used for Policy, Exceptions/Exemptions, Enforcement).

West Chester University - https://www.wcupa.edu/infoServices/documents/Vulnerability_Management_Policy.pdf (Used for Purpose, Scope)